

MODULE 03 · DOMAIN 1 - DESIGN SOLUTIONS FOR ORGANIZATIONAL COMPLEXITY

Control Tower and Landing Zones

Opinionated Organizations. Know what it automates and what it refuses to.

DOMAIN 1 of 4 EXAM WEIGHT 26% MODULE 3 of 44

Control Tower does nothing Organizations cannot do. It does it **the same way every time.**

What Control Tower actually orchestrates

- ◆ **AWS Organizations** for the account tree, SCPs and RCPs.
- ◆ **AWS Service Catalog** underneath Account Factory. Vended accounts are provisioned products.
- ◆ **IAM Identity Center** for single sign-on and pre-built permission sets.
- ◆ **AWS Config** and **CloudTrail**, configured organisation-wide with logs centralised.
- ◆ **CloudFormation**, both to build the landing zone and to run proactive control hooks.
- ◆ It is an orchestration layer. Nothing here is a new service you have not already met.

ON THE EXAM

Naming the underlying services makes the limits obvious. Control Tower inherits every constraint they have.

What you get on day one

- ◆ A **Security OU**, created automatically. This one is required.
- ◆ A **Log Archive account** holding immutable CloudTrail and Config history for every account.
- ◆ An **Audit account** for security teams, with cross-account read access and notifications.
- ◆ A **Sandbox OU**, offered during setup. Recommended but optional.
- ◆ The **Infrastructure OU** and **Workloads OU** are recommended but **not created for you**.

ON THE EXAM

Security OU with Log Archive and Audit is automatic. Everything else in the reference diagram is your job.

The three control types

01

Proactive

CloudFormation hooks. Blocks non-compliant resources before provisioning.

02

Preventive

SCPs, RCPs and declarative policies. Denies the API call outright.

03

Detective

Config rules. Reports non-compliance after the fact.

ON THE EXAM

Three answers to one question: at what moment do you want to be stopped?

The three types in detail

TYPE	BUILT ON	STOPS IT?	BLIND SPOT
Preventive	SCPs, RCPs, declarative policies	Yes, at the API call	Management account is exempt
Proactive	CloudFormation hooks	Yes, before provisioning	Only sees CloudFormation
Detective	AWS Config rules	No, reports only	Damage already done

ON THE EXAM

Only preventive controls stop every path. Proactive controls stop only the CloudFormation path.

A proactive control only inspects CloudFormation. The console, the CLI, the SDKs and Terraform **walk straight past it.**

The three guidance levels

- ◆ **Mandatory.** Always applied, cannot be disabled. These protect the landing zone itself.
- ◆ **Strongly recommended.** Enabled by choice, based on AWS best practice. Disable if you must.
- ◆ **Elective.** Optional controls for common but not universal requirements.
- ◆ Guidance level is about **whether you can turn it off**. It says nothing about how the control works.
- ◆ Controls apply to an **OU**, and reach every account inside it, including nested OUs.

ON THE EXAM

Do not confuse the three guidance levels with the three control types. They are unrelated axes.

Drift, and why the exam likes it

- ◆ **Drift is divergence from what Control Tower expects.** Someone changed something outside Control Tower.
- ◆ Editing a Control Tower SCP directly in Organizations causes drift. So does moving an account between OUs by hand.
- ◆ Removing an account from the organisation, or deleting the Log Archive configuration, both drift.
- ◆ Control Tower detects drift and reports it. **It does not silently repair it.**
- ◆ The fix is to repair the change, then **re-register the OU** or update the landing zone.

ON THE EXAM

Adopting Control Tower means changes go through Control Tower. Working around it in Organizations is the definition of drift.

Control Tower or plain Organizations?

CONTROL TOWER FITS WHEN

You want a repeatable environment

- Many accounts, provisioned continuously
- Standard logging and audit is the ask
- Compliance wants consistent baselines
- A small team governs many accounts

PLAIN ORGANIZATIONS FITS WHEN

You need something it will not do

- A bespoke structure that must not change
- Requirements outside supported controls
- Mature automation already does this
- You need governance at the Root

THE TIEBREAKER

Consistency at scale means Control Tower. One unusual requirement it cannot express means Organizations directly.

Three ways to vend an account

APPROACH	WHAT IT IS	REACH FOR IT WHEN
Account Factory	The built-in console template	Standard accounts, low volume, humans clicking
Account Factory for Terraform	Terraform pipeline on top of Account Factory	You want accounts defined as code, with customisation per account
Customizations for Control Tower	CloudFormation and SCP pipeline, triggered on account events	You need extra resources or policies deployed into every new account

ON THE EXAM

Account Factory creates the account. AFT and CfCT are how you make every new account arrive already configured.

Reading the scenario

THE SCENARIO SAYS

Must be blocked however the resource is created

Block it during CloudFormation deployment

Report which accounts are non-compliant

Someone changed an SCP directly in Organizations

Every new account must arrive with a VPC and roles

One control must apply at the Root

IT IS POINTING AT

Preventive control

Proactive control

Detective control

Drift

Customizations, or AFT

Control Tower cannot; use Organizations

ON THE EXAM

Most Control Tower questions turn on how the resource is created, or on stop versus report.

Meridian Freight uses Control Tower across 90 accounts. A compliance rule states that no EBS volume may be created unencrypted, anywhere, ever. The platform team enables the proactive control that requires EBS encryption on the Workloads OU.

Two months later an audit finds unencrypted volumes in three accounts. All three teams provision infrastructure with Terraform.

Why did the control fail to prevent this?

- ☐ A Proactive controls only inspect CloudFormation deployments
- ☐ B The control was applied to the OU rather than to each account
- ☐ C Proactive controls report non-compliance but do not block it
- ☐ D Terraform accounts must be enrolled in Control Tower separately

◆ PAUSE AND DECIDE

Why did the control fail to prevent this?

- A

 Only inspects CloudFormation
A proactive control is a CloudFormation hook. Terraform calls the EC2 API directly, so the hook is never invoked.
- B

 Applied to the OU
Backwards. Controls are designed to attach to an OU and reach every account inside it. That is the correct placement.
- C

 Proactive controls only report
Describes a detective control. Proactive controls genuinely do block, but only on the path they can see.
- D

 Separate enrolment
Enrolment is per account, not per tool. The accounts are enrolled; the deployment method is what differs.

THE SIGNAL

Three teams, all using Terraform, is the planted detail. It tells you the creation path avoids CloudFormation entirely.

A company is moving 300 developer teams onto AWS over 18 months. Each team needs its own account. Security requires identical CloudTrail, Config and log centralisation in every account, and wants to demonstrate that to an auditor.

The cloud platform team has four engineers.

What should the solutions architect recommend?

- ☐ A Build the structure in AWS Organizations with custom SCPs and a CloudFormation pipeline
- ☐ B Deploy a Control Tower landing zone and vend accounts through Account Factory
- ☐ C Create a single account with 300 IAM roles, one per team
- ☐ D Use AWS Config conformance packs applied to each account individually

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

Hand-built Organizations
Would work, and four engineers building and maintaining it for 300 accounts is exactly the overhead Control Tower removes.
- B

Control Tower landing zone
Standard baseline, identical in every vended account, with central logging and a dashboard the auditor can be shown.
- C

One account, 300 roles
Abandons account isolation, shared quotas, and any per-team billing separation. It solves none of the stated requirements.
- D

Conformance packs per account
Detective only, and applying them individually 300 times is the manual effort the scenario is trying to avoid.

THE SIGNAL

Identical baseline, many accounts, small team, and an auditor to satisfy. That combination is the landing zone use case exactly.

A security engineer needs a hard block on any account being able to disable CloudTrail. Control Tower is deployed with all mandatory controls active.

During testing, the engineer signs in to the management account and successfully stops a trail. The same attempt from a workload account is denied as expected.

What is the correct interpretation?

- ☐ A The mandatory control is misconfigured and should be re-enabled
- ☐ B Preventive controls do not apply to the management account; this is expected behaviour
- ☐ C The management account has drifted and needs re-enrolment
- ☐ D Mandatory controls apply only to accounts vended by Account Factory

◆ PAUSE AND DECIDE

What is the correct interpretation?

- A

 Misconfigured control
The workload account was correctly denied, which proves the control is working. Only the management account behaved differently.
- C

 Drift
Drift is a change made outside Control Tower. Nothing was changed here; a documented exemption was observed.
- B

 Expected; management account is exempt
Preventive controls are SCPs and RCPs, and neither applies to the management account. Control Tower inherits that limitation exactly.
- D

 Only vended accounts
Invented. Enrolled accounts are governed whether Account Factory created them or they were enrolled later.

THE SIGNAL

This is module two's exemption reappearing. Control Tower is built on Organizations, so it inherits every one of its limits.

Every new account at a company must arrive with a standard VPC, three IAM roles for the operations team, and a budget alarm. Accounts are created roughly twice a week through Account Factory.

Today an engineer applies these manually after each account is vended, and has forgotten twice this quarter.

What should the solutions architect recommend?

- ☐ A Add the resources to a Control Tower proactive control
- ☐ B Deploy Customizations for AWS Control Tower to apply the baseline on account creation
- ☐ C Enable additional strongly recommended controls on the OU
- ☐ D Write an AWS Config rule that flags accounts missing the resources

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Proactive control

Controls restrict what may be created. None of the three control types deploys resources into an account.

C More controls on the OU

Same category error as A. Controls govern behaviour; they do not provision a VPC.

B Customizations for Control Tower

Purpose-built for this. It triggers on account creation or enrolment and deploys CloudFormation templates into the new account.

D Config rule

Detects the omission after it has happened, which is what the engineer already discovers manually. It creates nothing.

THE SIGNAL

Controls restrict. Customizations deploy. If the requirement is that something must exist, no control can deliver it.

An organisation runs Control Tower. A platform engineer needed an urgent exception, so they edited one of the Control Tower service control policies directly in the AWS Organizations console.

The Control Tower dashboard now reports the OU as out of compliance, although the SCP is functioning as the engineer intended.

What should the team do?

- ☐ A Ignore it; the SCP works, and the dashboard status is cosmetic
- ☐ B Revert the manual change, then re-register the OU in Control Tower
- ☐ C Delete and rebuild the landing zone
- ☐ D Remove the affected accounts from the organisation and re-enrol them

◆ PAUSE AND DECIDE

What should the team do?

- A

 Ignore the drift
Tempting because nothing is visibly broken. But Control Tower will overwrite the change on the next landing zone update, silently removing the exception.
- B

 Revert, then re-register the OU
The documented drift remediation. It restores the expected state and returns the OU to a governed condition.
- C

 Rebuild the landing zone
Enormously disruptive for a single policy edit. Drift has a targeted remedy and this is not it.
- D

 Re-enrol the accounts
The drift is at the OU and its policy, not in the accounts. Re-enrolling them does not touch the edited SCP.

THE SIGNAL

Drift is not cosmetic. The next landing zone update reconciles to Control Tower's expected state, and the manual change disappears.

A regulator requires evidence, updated continuously, of which accounts have public S3 buckets. The company must also be able to prove the check has run without interruption for the past year.

The security team has asked whether a preventive control would satisfy the regulator.

What should the solutions architect advise?

- ☐ A A preventive control, because preventing the problem is stronger than reporting it
- ☐ B A detective control, because the requirement is continuous evidence rather than prevention
- ☐ C A proactive control, because it stops the bucket before it exists
- ☐ D No control is needed; S3 Block Public Access covers the requirement

◆ PAUSE AND DECIDE

What should the solutions architect advise?

A Preventive control

Stops the bucket but produces no ongoing compliance record. A control that blocks everything has nothing to report.

C Proactive control

Also preventive in effect, also produces no evidence trail, and only sees CloudFormation.

B Detective control

Config rules evaluate continuously and retain a compliance history, which is precisely the evidence the regulator asked for.

D Block Public Access alone

A sound configuration, and worth having, but it generates no per-account compliance record over time.

THE SIGNAL

Evidence is a detective requirement. Prevention is a strong instinct and the wrong answer when the ask is to demonstrate, not to stop.

What to carry out of this module

- ◆ **Proactive controls only see CloudFormation.** Console, CLI, SDK and Terraform bypass them.
- ◆ **Preventive stops at the API. Detective reports. Proactive stops at deployment.**
- ◆ Preventive controls are SCPs and RCPs, so the management account exemption applies here too.
- ◆ Controls restrict. **Customizations and AFT deploy.** No control creates a resource.
- ◆ Control Tower creates the Security OU. Infrastructure and Workloads OUs are yours.

ON THE EXAM

Two questions answer most Control Tower scenarios: how is the resource being created, and does the requirement say stop or say report?